

# JOUR 1 :

## RGPD : Règlement Général sur la Protection des Données X-Corp:

### Acteurs du traitement:

| <u>Acteur</u>                             | <u>Rôle chez X-Corp</u>                                                                                                                                                                                                                                                                                     |
|-------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Responsable du traitement                 | X-Corp, qui détermine les finalités (personnalisation d'offres, suivi de patients, suivi pédagogique) et les moyens (DataManage, MarketInsight, AutoMail) des traitements réalisés pour ses clients RetailCo, HealthMed et EduLearn.                                                                        |
| Sous-traitants                            | CloudSecure (hébergement et stockage cloud sécurisé des données) et AdBoost (diffusion de publicité ciblée à partir de segments transmis par X-Corp). Ces prestataires traitent des données pour le compte de X-Corp et doivent être liés par un contrat de sous-traitance conforme à l'article 28 du RGPD. |
| Personnes concernées                      | Les clients de RetailCo (≈800 000), les patients de HealthMed (≈500 000) et les utilisateurs d'EduLearn (≈300 000), dont les données transitent par les outils de X-Corp.                                                                                                                                   |
| DPO (Délégué à la Protection des Données) | Un DPO a été désigné chez X-Corp ; il supervise la conformité, conseille sur les DPIA et constitue le point de contact avec la CNIL et les personnes concernées.                                                                                                                                            |
| Autorité de contrôle                      | La CNIL, le siège social de X-Corp se situant à Paris.                                                                                                                                                                                                                                                      |

### Bases légales mobilisées:

L'article 6 du RGPD impose qu'un traitement repose sur une base légale parmi les six prévues. X-Corp mobilise principalement le consentement (article 6-1-a) pour l'ensemble de ses traitements :

- **RetailCo — DataManage** : Personnalisation des offres et promotions pour les clients de RetailCo, sur la base du consentement recueilli lors de l'inscription ou de l'achat.
- **HealthMed — DataManage** : Suivi des traitements et rappels de rendez-vous pour les patients de HealthMed, sur la base du consentement explicite (renforcé, car il s'agit de données de santé, catégorie particulière au sens de l'article 9).
- **EduLearn — MarketInsight** : Amélioration des parcours pédagogiques et recommandations de cours, sur la base du consentement des utilisateurs.
- **AutoMail** : Envoi de campagnes emailing ciblées, où le consentement doit être spécifique à la finalité marketing et distinct des autres consentements (opt-in dédié), conformément à la directive ePrivacy et au RGPD.

### Evaluation des risques:

- **Risque lié à la sensibilité des données** : Les données de santé traitées pour HealthMed relèvent de l'article 9 (catégories particulières de données) et exposent les patients à un risque élevé en cas de fuite.
- **Risque lié à l'anonymisation** : MarketInsight utilise l'IA pour prédire des tendances et segmenter les audiences, ce qui peut conduire à des décisions individuelles automatisées ou à une atteinte à la vie privée par recoupement de données comportementales.

- **Risque de violation de données** : X-Corp a déjà subi une fuite de données exposant 2 000 enregistrements clients, révélant des lacunes dans le processus de réponse aux incidents — un risque de récurrence existe tant que ce processus n'est pas renforcé.
- **Risque organisationnel** : Le volume important de demandes de droit d'accès (50 à 100 par mois) et les difficultés de gestion des consentements marketing traduisent un risque de non-conformité procédurale.

## Concepts clés:

“ Les concepts clés du RGPD régissent la manière dont les données à caractère personnel sont collectées, stockées et gérées. Ces concepts et principes sont au cœur du RGPD. Ils permettent aux personnes physiques d'exercer un meilleur contrôle sur les informations à caractère personnel les concernant et garantissent que les organisations traitent les données à caractère personnel de manière responsable. “

[https://www.edpb.europa.eu/topics/key-gdpr-concepts\\_fr](https://www.edpb.europa.eu/topics/key-gdpr-concepts_fr)

## 1. Licéité du traitement (RGPD - article 6)

Un traitement de données personnelles n'est licite que s'il repose sur au moins une des six bases prévues par le RGPD : consentement, exécution d'un contrat, obligation légale, sauvegarde des intérêts vitaux, mission d'intérêt public, ou intérêt légitime.

-> **Exemple:** X-Corp fonde la quasi-totalité de ses traitements (RetailCo, HealthMed, EduLearn) sur le consentement des personnes concernées, recueilli à l'inscription ou à l'achat.

## 2. Finalité du traitement

Les données doivent être collectées pour des **finalités déterminées, explicites et légitimes**, et ne peuvent ensuite être traitées d'une manière incompatible avec ces finalités initiales.

-> **Exemple:** Les données collectées via DataManage pour personnaliser les offres de RetailCo ne peuvent pas être réutilisées par MarketInsight pour prédire des tendances de

marché sans nouvelle base légale ou information des personnes concernées, sous peine de détournement de finalité.

### **3. Minimisation des données**

Seules les données **strictement nécessaires** à la finalité poursuivie doivent être collectées et traitées.

*-> **Exemple:** Pour la segmentation d'audience réalisée par MarketInsight, X-Corp doit s'assurer de ne collecter que les données comportementales pertinentes (pages visitées, interactions) et éviter des données superflues comme la géolocalisation précise si elle n'est pas utile à la finalité marketing.*

### **4. Protection particulière des données sensibles (RGPD - article 9)**

Certaines catégories de données (santé, origine raciale ou ethnique, opinions politiques, données biométriques, etc.) bénéficient d'une **protection renforcée** et ne peuvent être traitées que dans des cas limitativement énumérés, avec le consentement explicite de la personne.

*-> **Exemple:** Les données de santé et l'historique médical traités pour HealthMed relèvent de cette catégorie : X-Corp doit recueillir un consentement explicite (déjà en place) et appliquer des mesures de sécurité renforcées, ce qui justifie la pseudonymisation et le chiffrement AES-256 déployés.*

### **5. Conservation limitée des données**

Les données ne doivent pas être conservées au-delà de la durée nécessaire à la finalité pour laquelle elles ont été collectées ; des durées de conservation précises doivent être définies et justifiées.

*-> **Exemple:** X-Corp applique des durées différenciées selon le client : 5 ans après le dernier contact pour RetailCo, 10 ans après la fin du traitement médical pour HealthMed (durée alignée sur les obligations légales du secteur de la santé), et 2 ans après la fin d'utilisation pour EduLearn, avec une revue de la politique de conservation tous les 2 ans.*

### **6. Obligation de sécurité (RGPD - article 32)**

Le responsable de traitement doit mettre en œuvre des mesures techniques et organisationnelles adaptées au risque, afin de **garantir la confidentialité, l'intégrité et la disponibilité** des données.

*-> **Exemple:** X-Corp a déployé plusieurs mesures : pseudonymisation des données sensibles, chiffrement en transit et au repos (AES-256), authentification à deux facteurs pour les accès internes, et contrôle d'accès basé sur les rôles (RBAC) limitant l'accès aux données strictement nécessaires à chaque fonction.*

## 7. Transparence

Les personnes concernées doivent recevoir une **information claire, accessible et compréhensible** sur la manière dont leurs données sont collectées et utilisées (identité du responsable de traitement, finalités, durées de conservation, droits, destinataires).

*-> Exemple: Les clients de RetailCo, les patients de HealthMed et les utilisateurs d'EduLearn doivent être informés, via une politique de confidentialité claire au moment de la collecte, de l'usage fait de leurs données par DataManage, MarketInsight et AutoMail, ainsi que du recours à des sous-traitants comme CloudSecure et AdBoost.*

## 8. Droits des personnes

Le RGPD garantit aux personnes un ensemble de droits sur leurs données : droit d'accès, de rectification, d'effacement, à la limitation du traitement, à la portabilité, d'opposition, et droit de ne pas faire l'objet d'une décision entièrement automatisée.

*-> Exemple: X-Corp reçoit entre 50 et 100 demandes de droit d'accès par mois, ce qui constitue un volume significatif à traiter dans le délai légal d'un mois ; un processus dédié et outillé est nécessaire pour répondre efficacement, notamment pour les demandes concernant les données de santé gérées pour HealthMed.*

# Jour 2 :

## Registre des traitements:

L' article 30 du RGPD impose au responsable de traitement (et, dans certains cas, au sous-traitant) de tenir un registre des activités de traitement.

### Définition:

Le registre de traitement est un inventaire structuré qui permet, à tout moment, de savoir **qui traite quoi, pourquoi, comment et pour combien de temps**.

### **Pourquoi il existe :**

C'est l'outil central du principe de responsabilité du RGPD : l'organisation doit pouvoir démontrer sa conformité. Le registre sert de preuve et de tableau de bord, c'est souvent le premier document demandé par la CNIL en cas de

contrôle.

### Qui doit le tenir

- Le **responsable de traitement** , ici X-Corp.
- Le **sous-traitant** aussi, mais avec un registre différent, limité aux traitements qu'il effectue pour le compte d'autrui (donc CloudSecure ou AdBoost auraient leur propre registre)
- En théorie, les structures de moins de 250 salariés en sont dispensées, sauf si le traitement est régulier, touche des données sensibles, ou présente un risque pour les personnes — ce qui est justement le cas de X-Corp (données de santé, traitement régulier), donc l'obligation s'applique pleinement.

### Ce qu'il doit contenir, pour chaque traitement :

- le nom et la finalité du traitement
- les catégories de personnes concernées et de données traitées
- la base légale
- les destinataires (internes et externes/sous-traitants)
- la durée de conservation
- les mesures de sécurité

### A noter:

Le registre ne remplace pas la DPIA (qui analyse les risques d'un traitement précis) ni la politique de confidentialité (destinée aux personnes concernées, pas à l'autorité de contrôle). C'est un document interne à mettre à jour à chaque nouveau traitement ou changement significatif.

## Exemple de registre de traitement en utilisant X-Corp et ses sous-traitants:

| Nom du traitement                             | Responsable du traitement | Finalité(s) du traitement                                                                      | Base légale (art. 6 / art. 9)                                           | Catégories de personnes concernées                                               | Catégories de données traitées                                                                                     | Destinataires internes            | Destinataires externes / Sous-traitants                                  | Durée de conservation                                                                   | Mesures de sécurité                                                                                                                   |
|-----------------------------------------------|---------------------------|------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|----------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|-----------------------------------|--------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| Gestion des clients — RetailCo (DataManage)   | X-Corp                    | Personnalisation des offres et promotions, amélioration de l'expérience client                 | Consentement (art. 6-1-a)                                               | Clients de RetailCo (particuliers)                                               | Identité (nom, adresse), contact (email, téléphone), historique d'achats, préférences produits                     | Service marketing, service client | CloudSecure (hébergement cloud), AdBoost (diffusion publicitaire ciblée) | 5 ans après le dernier contact                                                          | Pseudonymisation, chiffrement AES-256 (transit + repos), authentification à deux facteurs, contrôle d'accès basé sur les rôles (RBAC) |
| Suivi des patients — HealthMed (DataManage)   | X-Corp                    | Suivi des traitements médicaux, rappel des rendez-vous, personnalisation des conseils de santé | Consentement explicite (art. 9-2-a — données de santé)                  | Patients de HealthMed (particuliers)                                             | Identité (nom, adresse), contact (email, téléphone), historique médical, prescriptions — données de santé (art. 9) | Service médical / suivi patient   | CloudSecure (hébergement cloud)                                          | 10 ans après la fin du traitement médical                                               | Pseudonymisation, chiffrement AES-256 (transit + repos), authentification à deux facteurs, RBAC                                       |
| Analyse de l'usage — EduLearn (MarketInsight) | X-Corp                    | Amélioration des parcours d'apprentissage, recommandations de cours, suivi des progrès         | Consentement (art. 6-1-a)                                               | Utilisateurs de la plateforme EduLearn (particuliers, potentiellement mineurs)   | Identifiant utilisateur, email, parcours d'apprentissage, résultats d'examen                                       | Service produit / data            | CloudSecure (hébergement cloud)                                          | 2 ans après la fin de l'utilisation de la plateforme                                    | Pseudonymisation, chiffrement AES-256 (transit + repos), authentification à deux facteurs, RBAC                                       |
| Campagnes emailing — AutoMail                 | X-Corp                    | Envoi de campagnes marketing ciblées basées sur le comportement des utilisateurs               | Consentement (art. 6-1-a) — opt-in marketing distinct requis (ePrivacy) | Clients / prospects de RetailCo, HealthMed, EduLearn ayant consenti au marketing | Email, données comportementales et de segmentation issues de DataManage                                            | Service marketing                 | AdBoost (publicité ciblée), CloudSecure (hébergement)                    | Alignée sur le traitement source (cf. lignes 1 à 3) ou jusqu'au retrait du consentement | Pseudonymisation, chiffrement, RBAC : gestion des consentements signalée comme perfectible                                            |

# Jour 3 :

## ANALYSE D'IMPACT RELATIVE À LA PROTECTION DES DONNÉES (DPIA)

### 1. Contexte

Ce traitement a été sélectionné pour la DPIA car il porte sur des données de santé (catégorie particulière au sens de l'article 9 du RGPD), traitées à grande échelle (≈ 500 000 patients) et pour le compte d'un client tiers (HealthMed). Il répond ainsi à plusieurs critères de la liste de la CNIL rendant une analyse d'impact obligatoire (article 35-3-b et lignes directrices du CEPD : traitement à grande échelle de données sensibles).

|                                  |                                                                                                                               |
|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| Responsable du traitement        | X-Corp (éditeur de la solution DataManage, utilisée pour le compte de son client HealthMed)                                   |
| Client / destinataire du service | HealthMed — société de services de santé (≈ 500 000 patients)                                                                 |
| DPO référent                     | DPO désigné chez X-Corp, à associer à la validation de cette DPIA                                                             |
| Finalité du traitement           | Suivi des traitements médicaux, rappel des rendez-vous, personnalisation des conseils de santé                                |
| Données traitées                 | Identité (nom, adresse), contact (email, téléphone), historique médical, prescriptions — données de santé au sens de l'art. 9 |
| Personnes concernées             | Patients de HealthMed, dont certains peuvent être des personnes vulnérables (patients en traitement long, personnes âgées)    |
| Support des données              | Base de données DataManage hébergée par CloudSecure (cloud), accès via applications internes X-Corp / HealthMed               |
| Durée de conservation            | 10 ans après la fin du traitement médical                                                                                     |

### 2. Principes fondamentaux : proportionnalité et nécessité

#### 2.1 Finalités déterminées, explicites et légitimes

Les finalités déclarées (suivi thérapeutique, rappels de rendez-vous, conseils personnalisés) sont légitimes au regard de l'activité de HealthMed et suffisamment précises. Point de vigilance : il convient de vérifier que « personnalisation des conseils de santé » ne dérive pas vers un usage marketing ou vers un profilage de santé non couvert par le consentement initial, ce qui constituerait un détournement de finalité.

#### 2.2 Licéité, minimisation et qualité des données

- **Base légale** : consentement explicite recueilli auprès des patients (art. 9-2-a), ce qui est adapté à la sensibilité des données.



- **Minimisation** : “l'historique médical” et les “prescriptions” sont des catégories larges ; il est recommandé de vérifier que seules les informations nécessaires au suivi (et non l'intégralité du dossier médical) sont importées dans DataManage.
- **Exactitude** : un processus de mise à jour des données (changement de traitement, de coordonnées) doit exister pour garantir l'exactitude des informations utilisées pour les rappels et conseils.

### 2.3 Durées de conservation et droits des personnes

- **Conservation** : 10 ans après la fin du traitement médical ; cette durée est cohérente avec les obligations légales applicables aux données de santé en France, mais son point de départ (« fin du traitement ») doit être défini précisément et objectivement (ex. date de dernière consultation).
- **Droits des personnes** : information claire lors de la collecte, recueil du consentement explicite, procédure d'exercice des droits (accès, rectification, effacement, portabilité, opposition). Le volume de 50 à 100 demandes de droit d'accès par mois pour l'ensemble de X-Corp implique un processus dédié et tracé, avec une attention particulière pour les demandes portant sur des données de santé (délai légal d'un mois).

## 3. Étude des risques sur la sécurité des données

Conformément à la méthodologie de la CNIL, les risques sont analysés selon trois événements redoutés : l'accès illégitime aux données, la modification non désirée de données, et la disparition de données. Pour chacun, la gravité (impact sur les personnes) et la vraisemblance (probabilité de survenance) sont estimées sur une échelle à 4 niveaux : Négligeable, Limitée, Importante, Maximale.

|                     | Accès illégitime aux données                                                                                                                                                                           | Modification non désirée des données                                                                                                                                                                        | Disparition des données                                                                                                                                                             |
|---------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Sources de risques  | Attaquant externe (piratage, hameçonnage), employé de X-Corp ou de HealthMed accédant à des données hors de ses fonctions, faille chez le sous-traitant CloudSecure, interception lors d'un transfert. | Erreur humaine lors de la saisie ou de l'import, altération malveillante par un tiers ayant obtenu un accès, dysfonctionnement lors d'une synchronisation entre systèmes (DataManage / dossiers HealthMed). | Panne technique ou sinistre chez l'hébergeur CloudSecure, erreur de suppression, rançongiciel (ransomware), fin de contrat avec un sous-traitant sans reprise correcte des données. |
| Menaces réalisables | Vol d'identifiants (phishing), exploitation d'une vulnérabilité applicative de DataManage, contournement du contrôle d'accès par rôles (RBAC), accès non autorisé chez le sous-traitant.               | Modification erronée d'une prescription ou d'un historique médical, altération de données lors d'une intégration technique défectueuse, sabotage interne.                                                   | Cyberattaque de type rançongiciel bloquant l'accès aux données, perte de sauvegardes, suppression accidentelle par un administrateur.                                               |

|                                             |                                                                                                                                                                                                                                                                                                                                                 |                                                                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                                        |
|---------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Impacts potentiels sur les personnes</b> | Atteinte à la vie privée et à la dignité des patients (données de santé exposées), risque de discrimination (assurance, emploi), stigmatisation, perte de confiance envers HealthMed et X-Corp, sanctions RGPD pour X-Corp.                                                                                                                     | Risque direct pour la santé du patient si une prescription ou un historique est corrompu (erreur de suivi médical), perte de confiance, mise en cause de la responsabilité de X-Corp et HealthMed.                                                                                           | Rupture du suivi médical des patients (rendez-vous manqués, absence d'historique pour les soignants), impossibilité de répondre aux demandes de droit d'accès, non-conformité à l'obligation de disponibilité (art. 32).                                               |
| <b>Mesures existantes</b>                   | Pseudonymisation des données sensibles, chiffrement AES-256 (transit et repos), authentification à deux facteurs, contrôle d'accès basé sur les rôles (RBAC). Mesures complémentaires recommandées : journalisation et revue régulière des accès, tests d'intrusion périodiques, clause de sécurité renforcée dans le contrat avec CloudSecure. | RBAC limitant les droits d'écriture, chiffrement et contrôles d'intégrité. Mesures complémentaires recommandées : journal des modifications (traçabilité, horodatage, auteur), mécanisme de validation/double contrôle pour les données médicales critiques, sauvegardes régulières testées. | Chiffrement et infrastructure cloud sécurisée (CloudSecure). Mesures complémentaires recommandées : politique de sauvegarde régulière et testée (restauration), plan de continuité d'activité (PCA) formalisé, clause contractuelle de réversibilité avec CloudSecure. |
| <b>Gravité</b>                              | <b>Maximale</b>                                                                                                                                                                                                                                                                                                                                 | <b>Maximale</b>                                                                                                                                                                                                                                                                              | <b>Importante</b>                                                                                                                                                                                                                                                      |
| <b>Vraisemblance</b>                        | Importante                                                                                                                                                                                                                                                                                                                                      | Limité                                                                                                                                                                                                                                                                                       | Limité                                                                                                                                                                                                                                                                 |

## 4. Plan d'action et recommandations

L'analyse fait apparaître un traitement globalement bien protégé sur le plan technique (chiffrement, RBAC, authentification renforcée), mais dont la gravité potentielle reste élevée compte tenu de la nature des données (santé) et du volume de personnes concernées. Les actions suivantes sont recommandées avant, ou en parallèle de, la mise en œuvre du traitement :

- **Traçabilité** : mettre en place une journalisation systématique des accès et modifications aux données de santé, avec revue périodique par le DPO.
- **Sous-traitance** : auditer le contrat de sous-traitance avec CloudSecure (article 28 du RGPD), vérifier la localisation des données et l'existence de garanties suffisantes (certifications, clauses de sécurité, réversibilité).
- **Tests de sécurité** : réaliser un test d'intrusion sur DataManage et un contrôle du processus de gestion des habilitations (RBAC) au moins une fois par an.
- **Continuité** : formaliser et tester un plan de sauvegarde/restauration ainsi qu'un plan de continuité d'activité pour les données HealthMed.
- **Conservation** : clarifier et documenter précisément le fait générateur de la conservation « 10 ans après la fin du traitement médical », et automatiser la purge/anonymisation à l'échéance.

- **Gestion des violations** : s'assurer que le processus de notification de violation à la CNIL (dans les 72h, art. 33) et aux personnes concernées (art. 34) est formalisé et testé.
- **Finalité** : vérifier que le champ « personnalisation des conseils de santé » ne dépasse pas la finalité initialement consentie et former les équipes marketing à ne pas réutiliser ces données pour des campagnes AutoMail sans base légale distincte.

## Jour 4 :

### GESTION D'INCIDENT: SIMULATION DE GESTION D'UNE VIOLATION DE DONNÉES

#### 1. Contexte du scénario

Cette simulation reprend le risque jugé le plus critique lors de la DPIA (accès illégitime aux données du traitement « Suivi des patients HealthMed », gravité maximale / vraisemblance importante). Elle s'inscrit également dans la continuité de l'incident réel mentionné dans le dossier d'audit : X-Corp a déjà subi, un an auparavant, une fuite de données mineure exposant 2 000 enregistrements clients, avec des lacunes identifiées dans le processus de réponse. Le scénario ci-dessous est un cas fictif construit pour tester et documenter un processus de réponse structuré.

#### 2. Description de l'incident (scénario fictif)

Un système de supervision détecte un volume anormal d'exports de données depuis la base DataManage, en dehors des horaires habituels d'utilisation. L'investigation révèle qu'un compte employé du service support a été compromis par hameçonnage (phishing) trois jours plus tôt. L'attaquant a utilisé ces identifiants pour accéder à la base de données des patients HealthMed et exporter un sous-ensemble de dossiers.

|                               |                                                                                                                                               |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| Traitement concerné           | Suivi des patients — HealthMed (module DataManage)                                                                                            |
| Vecteur d'attaque             | Hameçonnage (phishing) d'un compte employé du service support, puis contournement partiel du contrôle d'accès par rôles (RBAC)                |
| Données exposées              | Nom, adresse, email, téléphone, historique médical et prescriptions                                                                           |
| Volume estimé                 | ≈ 15 000 dossiers patients (sur les 500 000 gérés pour HealthMed)                                                                             |
| Type de violation (art. 4-12) | Violation de confidentialité (accès et exfiltration non autorisés). Pas d'atteinte constatée à l'intégrité ni à la disponibilité des données. |

### 3. Chronologie de la gestion de l'incident

| Etape                                 | Action réalisé                                                                                                                                                                 |
|---------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Détection                             | Alerte automatique du système de supervision (volume d'export anormal). L'équipe sécurité ouvre un ticket d'incident.                                                          |
| Activation cellule de crise           | Mobilisation de l'équipe sécurité, du DPO et du responsable technique DataManage. Le compte compromis est immédiatement suspendu.                                              |
| Confinement                           | Révocation de tous les jetons de session actifs, réinitialisation des mots de passe à risque, renforcement temporaire du contrôle d'accès sur DataManage.                      |
| Analyse d'impact                      | Investigation forensique : périmètre exact des données exportées (≈ 15 000 dossiers), confirmation qu'il s'agit de données de santé. Qualification de la violation par le DPO. |
| Evaluation du risque                  | Le DPO évalue le risque pour les personnes concernées comme élevé: décision de notifier la CNIL et les personnes concernées.                                                   |
| Information du client                 | HealthMed est informé de l'incident en tant que partenaire dont les patients sont concernés, avant toute notification externe.                                                 |
| Préparation de la notification        | Rédaction de la notification à la CNIL et du message aux personnes concernées ; consolidation des mesures correctives déjà mises en œuvre.                                     |
| Notification à la CNIL                | Notification transmise via le téléservice de la CNIL, dans le délai de 72 heures prévu à l'article 33 du RGPD.                                                                 |
| Communication au personnes concernées | Envoi du message d'information aux ≈ 15 000 patients concernés (art. 34).                                                                                                      |
| Remédiation et retour d'expérience    | Renforcement des mesures (MFA obligatoire, campagne anti-phishing, revue des habilitations), rédaction du rapport post-incident.                                               |

### 4. Évaluation du risque pour les personnes concernées

Selon la méthodologie de la CNIL, le risque est évalué à partir de la gravité potentielle des impacts et de leur vraisemblance :

- **Nature des données** : données de santé (catégorie particulière, art. 9), pouvant entraîner discrimination, stigmatisation ou atteinte à la vie privée en cas de divulgation.
- **Volume et vulnérabilité** : 15 000 patients, dont certains potentiellement vulnérables (patients en suivi médical de long terme).
- **Facilité d'identification et diffusion** : exfiltration confirmée vers un tiers non identifié : le risque de réutilisation malveillante ne peut être écarté.

**Conclusion** : le risque pour les droits et libertés des personnes concernées est qualifié d'élevé. Cette qualification déclenche deux obligations cumulatives : la notification à la CNIL (art. 33) et la communication directe aux personnes concernées (art. 34).

## **5. Notification à l'autorité de contrôle (article 33)**

Notification transmise à la CNIL dans le délai de 72 heures suivant la prise de connaissance de la violation. Exemple des éléments constitutifs de la notification :

### **Notification de violation de données — X-Corp**

**Nature de la violation :** Accès et exfiltration non autorisés de données de santé, consécutifs à la compromission d'un compte employé par hameçonnage.

**Catégories et nombre approximatif de personnes concernées :** ≈ 15 000 patients de HealthMed.

**Catégories et volume approximatif de données concernées :** Identité, coordonnées, historique médical et prescriptions (données de santé, art. 9).

**Nom et coordonnées du DPO :** [ ].

**Conséquences probables de la violation :** Risque d'atteinte à la vie privée, de discrimination ou de stigmatisation des patients concernés en cas d'exploitation malveillante des données de santé exposées.

**Mesures prises ou proposées :** Suspension du compte compromis, révocation des sessions actives, réinitialisation des accès à risque, renforcement du contrôle d'accès, authentification multi-facteurs généralisée, information de HealthMed et des patients, dépôt de plainte, campagne de sensibilisation anti-phishing.

## **6. Communication aux personnes concernées (article 34)**

Le risque étant qualifié d'élevé, X-Corp (pour le compte de HealthMed) informe individuellement chaque patient concerné, dans un langage clair et accessible.

Exemple de message :

Objet : Information importante concernant vos données personnelles

Madame, Monsieur,

Nous vous informons qu'un incident de sécurité a affecté certaines de vos données personnelles gérées dans le cadre de votre suivi avec HealthMed. Un accès non autorisé à notre système a permis l'exfiltration de données incluant votre identité, vos coordonnées et des éléments de votre historique médical.

Dès la détection de cet incident, nous avons immédiatement bloqué l'accès concerné, renforcé la sécurité de nos systèmes et informé la Commission Nationale de l'Informatique et des Libertés (CNIL), conformément à la réglementation.

Nous vous recommandons de rester vigilant face à d'éventuelles sollicitations suspectes (appels, emails) se présentant comme émanant de HealthMed ou de X-Corp, et de ne communiquer aucune information personnelle ou bancaire dans ce contexte.

Pour toute question, vous pouvez contacter notre Délégué à la Protection des Données à l'adresse [à compléter]. Vous disposez également d'un droit de réclamation auprès de la CNIL ([www.cnil.fr](http://www.cnil.fr)).

Nous vous prions de bien vouloir nous excuser pour la gêne occasionnée et vous assurons de notre mobilisation totale pour protéger vos données.

## **7. Registre interne des violations (article 33-5)**

Indépendamment de l'obligation de notification à la CNIL, chaque violation, y compris celles non notifiées, doit être consignée dans un registre interne.

Exemple d'entrée pour ce scénario :

Date de détection: XX.XX.XXXX

Traitement concerné = Suivi des patients HealthMed (DataManage)

Nature de la violation = Confidentialité: accès et exfiltration non autorisés

Personnes/volume = ≈ 15 000 patients HealthMed

Risque évalué = Élevé

Notification CNIL = Oui, dans le délai de 72h

Communication aux personnes = Oui.

Mesures correctives = MFA généralisé, revue RBAC, campagne anti-phishing, durcissement de la supervision des exports.

## **8. Mesures correctives et retour d'expérience**

- **Court terme** : campagne de sensibilisation obligatoire au phishing pour l'ensemble des équipes, en particulier le service support (vecteur d'entrée identifié).
- **Moyen terme** : authentification multi-facteurs rendue obligatoire (et non plus seulement disponible) pour tous les comptes accédant à des données de santé ; alertes automatiques sur les exports de volume anormal.
- **Structurel** : révision du processus de réponse à incident (fiche réflexe, astreinte, contacts CNIL pré-identifiés) afin de corriger les lacunes déjà relevées lors de la précédente fuite de données de X-Corp.
- **Retour d'expérience (RETEX)** : rapport d'incident formalisé, présenté au DPO et à la direction, alimentant l'audit de conformité global.

## Conclusion

Cette simulation met en évidence l'importance d'un processus de réponse structuré et chronométré : détection, confinement, qualification du risque, notification dans les délais légaux, communication transparente aux personnes concernées, puis remédiation. Elle confirme également, en écho à l'incident réel déjà survenu chez X-Corp, que le facteur humain (hameçonnage) reste le vecteur de risque le plus vraisemblable, ce qui oriente les priorités de l'audit de conformité final.

## Jour 5 :

### Audit de conformité

X-Corp, éditeur des solutions DataManage, MarketInsight et AutoMail, traite des données pour le compte de trois clients principaux (RetailCo, HealthMed, EduLearn), dont des données de santé à grande échelle. L'audit révèle une organisation dotée de fondations solides — DPO désigné, mesures de sécurité techniques avancées (chiffrement AES-256, RBAC, authentification à deux facteurs), DPIA menées avant chaque lancement produit — mais présentant des non-conformités récurrentes sur la gouvernance du consentement, la sous-traitance et le pilotage des risques de sécurité.

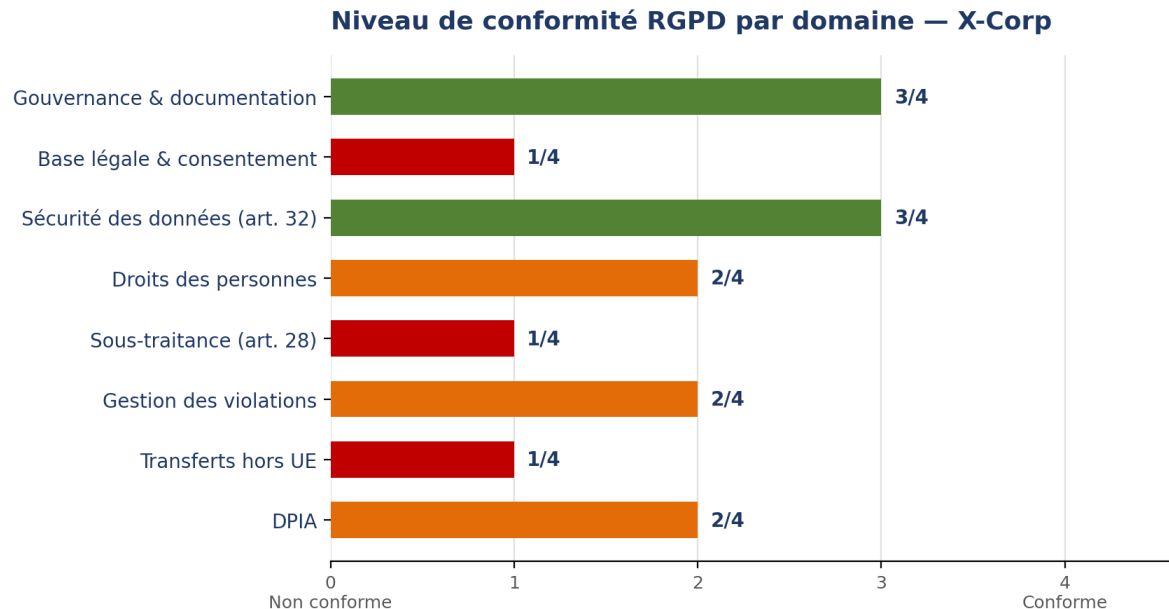
### 1. Méthodologie et périmètre

**Référentiel** : articles 5, 6, 9, 12 à 23, 28, 30, 32, 33-34 et 35 du RGPD ; guides et outils de conformité de la CNIL.

**Périmètre** : les trois produits de X-Corp (DataManage, MarketInsight, AutoMail) et les traitements réalisés pour RetailCo, HealthMed et EduLearn.

**Méthode** : analyse documentaire du dossier d'audit, élaboration du registre des traitements, réalisation d'une DPIA sur le traitement le plus à risque, simulation d'une violation de données.

## 2. Synthèse par domaine de conformité



| Domaine                      | Status       | Résultat                                                                                                                                                                                                                                                                                                 |
|------------------------------|--------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Gouvernance et documentation | Conforme     | DPO désigné, DPIA réalisées avant chaque lancement produit, politique de conservation revue tous les 2 ans. -> Point d'amélioration : le registre des traitements ne couvre pour l'instant que 4 traitements identifiés; les traitements internes (RH, comptabilité...) restent à cartographier.         |
| Base légale et consentement  | Non-Conforme | Le consentement est utilisé comme base légale quasi systématique, y compris là où l'exécution d'un contrat (suivi médical HealthMed) ou l'intérêt légitime (analyses MarketInsight) seraient plus adaptés. Difficultés confirmées de gestion et de documentation des consentements marketing (AutoMail). |



|                        |                        |                                                                                                                                                                                                                                                     |
|------------------------|------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Sécurité des données   | Conforme               | Mesures techniques solides : pseudonymisation, chiffrement AES-256, authentification à deux facteurs, contrôle d'accès par rôles (RBAC). Toutefois que le MFA n'est pas encore généralisé à tous les comptes sensibles.                             |
| Droit des personnes    | Partiellement Conforme | Volume important de demandes de droit d'accès (50 à 100/mois) sans procédure formalisée et outillée décrite dans le dossier d'audit, ce qui fait peser un risque de non-respect du délai légal d'un mois, en particulier pour les données de santé. |
| Sous-traitance         | Non-Conforme           | CloudSecure et AdBoost sont identifiés comme sous-traitants mais aucun élément du dossier ne confirme l'existence de contrats de sous-traitance conformes, ni la localisation exacte des données (transferts hors UE non identifiés).               |
| Gestion des violations | Partiellement Conforme | Un incident réel passé a révélé des lacunes dans le processus de réponse. La simulation effectuée a permis de documenter un scénario de bout en bout (détection à notification), mais ce processus reste à formaliser officiellement.               |
| Transferts hors-UE     | Non-Conforme           | Aucune information disponible sur la localisation des serveurs de CloudSecure ni sur d'éventuels transferts vers AdBoost hors UE. Point aveugle à lever en priorité.                                                                                |
| DPIA                   | Partiellement Conforme | Une DPIA est réalisée avant chaque nouveau produit, mais sans méthodologie formalisée démontrée                                                                                                                                                     |

→ **Hétérogénéité des traitements** : X-Corp traite des données pour le compte de trois secteurs très différents (retail, santé, éducation) avec un niveau de sensibilité variable, mais applique des mesures de sécurité globalement homogènes plutôt qu'une gradation par niveau de risque.

→ **Facteur humain** : identifié comme vecteur d'attaque vraisemblable dans la simulation d'incident et cohérent avec l'absence de formation anti-phishing mentionnée dans le dossier.

→ **Sous-outillage des processus RGPD** : les difficultés de gestion des consentements marketing et le volume de demandes de droit d'accès traduisent un besoin d'outillage (plateforme de gestion des consentements, portail self-service pour les demandes de droits).

### **3. Plan d'action**

a) Priorité: **Critique**

→ Base légale reposant quasi exclusivement sur le consentement, mal adaptée à certains traitements.

→ **Action recommandée**: Appliquer la base légale appropriée en fonction du traitement spécifique (contrat pour le suivi médical, intérêt légitime documenté pour certaines analyses) et mettre à jour les mentions d'information.

→ Sous-traitance non encadrée contractuellement (CloudSecure, AdBoost) et transferts hors UE non identifiés.

→ **Action recommandée** : Auditer et formaliser les contrats de sous-traitance (art. 28) ; cartographier la localisation des données et mettre en place les garanties de transfert requises (clauses contractuelles types).

b) Priorité: **Élevée**

→ MFA non généralisé ; facteur humain (phishing) identifié comme vecteur de risque principal.

→ **Action recommandée** : Rendre le MFA obligatoire sur tous les accès aux données sensibles; déployer une campagne de sensibilisation au phishing pour l'ensemble des équipes.

→ Processus de gestion des violations non formalisé.

→ **Action recommandée** : Rédiger une procédure écrite de réponse à incident (rôles, astreinte, modèles de notification CNIL/personnes) à partir du scénario testé.

c) Priorité: **Moyenne**

→ Registre des traitements incomplet (traitements internes non cartographiés)

→ **Action recommandée**: Étendre le registre à l'ensemble des traitements de X-Corp (RH, comptabilité, etc.) via des entretiens avec chaque service.

→ Gestion des consentements marketing peu maîtrisée ; volume élevé de demandes de droit d'accès.

→ **Action recommandée** : Déployer un outil de gestion des consentements (opt-in dédié pour AutoMail) et un portail structuré pour le traitement des demandes de droits.

## **4. Conclusion**

X-Corp dispose d'une base de conformité réelle, gouvernance en place, sécurité technique robuste, mais des angles morts significatifs subsistent, en particulier sur l'encadrement de la sous-traitance, les transferts de données et la cohérence des bases légales retenues. Le plan d'action ci-dessus, s'il est mis en œuvre selon les échéances proposées, permettrait de porter la conformité de X-Corp d'un niveau partiel à un niveau satisfaisant sur l'ensemble des domaines audités.